



IAMI

Confidentiel

RGPD et Sécurité



27.04.2026

TABLE OF CONTENTS

1.	CGU	6
1.1.	Objet.....	6
1.2.	Acceptation	6
1.3.	Compte Utilisateur	6
1.4.	Rôles et permissions	6
1.5.	Usage attendu	6
1.6.	Intelligence Artificielle	7
1.7.	Propriété intellectuelle	7
1.8.	Disponibilité	7
1.9.	Données Personnelles.....	7
1.10.	Responsabilité	7
1.11.	Suspension, résiliation.....	7
1.12.	Modification	8
1.13.	Droit applicable	8
1.14.	Contact.....	8
2.	CGV	8
2.1.	Objet.....	8
2.2.	Offres et souscription	8
2.3.	Durée et résiliation.....	8
2.4.	Tarifs et facturation	9
2.5.	Propriété intellectuelle	9
2.6.	Obligations de l'Éditeur	9
2.7.	Obligations du Client	9
2.8.	Responsabilité	9
2.9.	Confidentialité	10
2.10.	Sous-traitance	10



2.11.	Protection des données personnelles.....	10
2.12.	Assurance.....	10
2.13.	Force majeure.....	10
2.14.	Cession	10
2.15.	Droit applicable et litiges	10
2.16.	Contact.....	10
3.	SLA	10
3.1.	Disponibilité cible	10
3.2.	Fenêtre de maintenance.....	11
3.3.	Support	11
3.4.	Sauvegardes et continuité.....	11
3.5.	Surveillance et détection	11
3.6.	Gestion d'incident.....	12
3.7.	Sécurité (synthèse).....	12
3.8.	Notification de violation	12
3.9.	Rapport de service.....	12
3.10.	Réversibilité.....	12
3.11.	Contact.....	12
4.	ATD	12
4.1.	Parties	13
4.2.	Objet.....	13
4.3.	Description du traitement	13
4.4.	Obligations du Sous-Traitant.....	13
4.5.	Sous-traitance ultérieure	14
4.6.	Transferts hors UE	14
4.7.	Droits des personnes concernées	14
4.8.	Sécurité et notification de violation	14
4.9.	Fin du traitement.....	14
4.10.	Audit.....	14
4.11.	Durée et modification	15



4.12.	Responsabilité	15
4.13.	Droit applicable	15
5.	Sous-traitants	15
6.	Politique RGPD	16
6.1.	Responsable du traitement	17
6.2.	Quelles données collectons-nous ?	17
6.3.	Finalités et bases légales	17
6.4.	Destinataires	17
6.5.	Localisation	17
6.6.	Durées de conservation	17
6.7.	Vos droits	18
6.8.	Sécurité	18
6.9.	Cookies	18
6.10.	Violation de données	18
6.11.	Recours — CNIL	18
6.12.	Contact	19
6.13.	Modifications	19
7.	Politique de sécurité	19
7.1.	Hébergement	19
7.2.	Architecture applicative	19
7.2.1.	Isolation multi-tenant	19
7.2.2.	Contrôle d'accès (RBAC)	19
7.2.3.	Authentification	19
7.2.4.	Chiffrement	20
7.3.	Sécurité web	20
7.4.	Intelligence Artificielle	20
7.5.	Journalisation et audit	20
7.6.	Sauvegarde et reprise	20
7.7.	Sécurité du développement	21
7.8.	Gestion des tiers	21
7.9.	Accès internes	21



7.10.	Gestion des vulnérabilités.....	21
7.11.	Gestion d'incident.....	21
7.12.	Mesures organisationnelles	21
7.13.	Conformité.....	22
7.14.	Contact sécurité	22
8.	App Mobile	22
8.1.	Objet.....	22
8.2.	Données traitées via l'App.....	22
8.3.	Finalités.....	23
8.4.	Stockage sur l'appareil (iPhone / iPad)	23
8.5.	Communications réseau	23
8.6.	Périmètre des API et journaux serveurs	23
8.7.	Destinataires	23
8.8.	Durée de conservation	23
8.9.	Vos droits (RGPD)	24
8.10.	Modifications	24
8.11.	Contact.....	24



1.CGU

Éditeur : IAMI — 1 rue des liserons 75013 Paris— SIREN 999430242

Contact : contact@iamisolutions.com · 07.69.79.98.92

1.1. Objet

Les présentes Conditions Générales d'Utilisation (« CGU ») régissent l'accès et l'utilisation de la plateforme IAMI (la « Plateforme ») éditée par IAMI. La Plateforme est un outil SaaS destiné aux entreprises (principalement des ESN — Entreprises de Services du Numérique) pour la gestion des candidats, consultants, clients, prospects, entretiens, matching et assistance par intelligence artificielle locale.

1.2. Acceptation

L'utilisation de la Plateforme implique l'acceptation pleine et entière des présentes CGU par tout Utilisateur (salarié, consultant, administrateur ou candidat invité par un Client de l'éditeur).

1.3. Compte Utilisateur

L'accès est réservé aux Utilisateurs disposant d'un compte nominatif créé par l'administrateur du Client. Le partage d'identifiants est interdit. L'Utilisateur est responsable de la confidentialité de ses identifiants et signale toute compromission à contact@iamisolutions.com.

1.4. Rôles et permissions

La Plateforme applique un contrôle d'accès basé sur les rôles (RBAC). Chaque Utilisateur se voit attribuer des rôles (administrateur, recruteur, consultant, commercial...) qui délimitent strictement les fonctionnalités et données accessibles. L'attribution des rôles relève du Client.

1.5. Usage attendu

L'Utilisateur s'engage à :

- utiliser la Plateforme uniquement dans le cadre de son activité professionnelle légitime ;
 - ne pas saisir ou importer de données manifestement illicites, diffamatoires ou protégées sans base légale (en particulier, aucune donnée sensible au sens de l'art. 9 RGPD sans base juridique claire) ;
 - respecter les droits des personnes concernées (RGPD) dont il traite les données via la Plateforme ;
 - ne pas tenter de contourner les mesures de sécurité, injecter du code, scraper la Plateforme ou contourner les limitations techniques ;
 - ne pas utiliser la Plateforme pour du profilage prohibé ou constituer des fichiers illégaux.
 - ne pas déléguer à l'IA ou aux agents IA des décisions à impact juridique ou humain (ex : embauche, licenciement, évaluation, envoi de mail) sans validation humaine finale.
- L'Utilisateur ou le Client reste le responsable ultime de toute décision affectant une personne physique, conformément à l'article 22 du RGPD (droit de ne pas faire l'objet d'une décision fondée uniquement sur un traitement automatisé).



1.6. Intelligence Artificielle

La Plateforme intègre des modèles d'IA exécutés localement (LLM, embeddings sentence-transformers, LLM fine-tuné) sur notre infrastructure. Aucune donnée n'est transmise à OpenAI, Anthropic, Google, Mistral AI ou tout autre fournisseur d'IA externe.

Les sorties de l'IA sont des aides à la décision ou automatisation de processus. Les résultats de matching (correspondances candidats/offres, analyses de compétences, etc.) peuvent être utilisés par IAMl pour améliorer ses modèles d'IA de manière locale et agrégée, via des techniques de fine-tuning ou de renforcement par apprentissage (RL) exécutées exclusivement sur notre infrastructure (OVHcloud, UE). Aucune donnée brute (CV, entretiens, données personnelles) n'est transmise à des fournisseurs d'IA externes (OpenAI, Anthropic, Mistral AI, Google, etc.) ou quelconque fournisseur externe pour ces améliorations. Les données utilisées sont anonymisées ou agrégées, et ne permettent pas de ré-identifier une personne physique.

L'Utilisateur humain reste l'unique décideur pour toute décision concernant une personne (embauche, refus, évaluation, envoi de mail), conformément à l'article 22 du RGPD.

1.7. Propriété intellectuelle

La Plateforme, son code, ses interfaces, ses marques et logos sont la propriété exclusive de l'éditeur. Toute reproduction non autorisée est interdite. Les Données saisies par le Client restent sa propriété ; l'éditeur dispose d'une licence non-exclusive pour les traiter aux fins d'exécution du service (voir ATD Article 28).

1.8. Disponibilité

L'éditeur s'engage sur les niveaux de disponibilité décrits dans *[l'Engagement de service \(SLA\)](#)*.

1.9. Données Personnelles

Le traitement des données personnelles est régi par la *[Politique RGPD](#)* et, pour la relation contractuelle, par l'*[Accord de Traitement des Données](#)*. Chaque Utilisateur dispose des droits d'accès, rectification, effacement, limitation, opposition et portabilité (contact : contact@iamisolutions.com).

1.10. Responsabilité

L'éditeur met en œuvre les moyens techniques et organisationnels appropriés pour garantir la sécurité du service. Sa responsabilité ne saurait être engagée pour les dommages résultant d'une utilisation non conforme, d'une négligence de l'Utilisateur, d'un cas de force majeure ou d'un incident chez un sous-traitant. La responsabilité financière est limitée selon les CGV.

1.11. Suspension, résiliation



L'éditeur peut suspendre ou clôturer un compte en cas de violation grave ou répétée des CGU. À la fin de la relation contractuelle avec un Client, les comptes rattachés sont désactivés et les données effacées ou restituées conformément à l'ATD.

1.12. Modification

L'éditeur peut modifier les CGU à tout moment. La version en vigueur est celle publiée sur www.iamisolutions.com/legal/cgu.html.

1.13. Droit applicable

Les présentes CGU sont soumises au droit français. Tout litige relèvera de la compétence exclusive des tribunaux du ressort du siège social de l'éditeur, sauf dispositions d'ordre public contraires.

1.14. Contact

IAM I — 1 rue des liserons — SIREN 999430242

Support : contact@iamisolutions.com • 07.69.79.98.92

Données personnelles / DPO : dpo@iamisolutions.com

2. CGV

2.1. Objet

Les présentes CGV régissent les conditions de commercialisation de la plateforme SaaS IAM I entre IAM I (« l'Éditeur ») et toute personne morale souscrivant un abonnement (le « Client »).

2.2. Offres et souscription

L'offre se matérialise par un bon de commande ou contrat-cadre signé entre les Parties, précisant : nombre d'utilisateurs, périmètre fonctionnel, durée, tarif, modalités de paiement. L'offre comprend l'accès à la Plateforme, le support standard, les sauvegardes et les mises à jour. Les prestations d'intégration, de formation, de reprise de données et les développements spécifiques font l'objet d'un devis complémentaire.

2.3. Durée et résiliation

L'abonnement est souscrit pour une durée ferme (typiquement 12 mois), reconductible tacitement, sauf dénonciation par l'une ou l'autre partie au moins 3 mois avant l'échéance par lettre recommandée ou email certifié.

Résiliation pour faute : en cas de manquement grave et non réparé dans les 30 jours après mise en demeure, la Partie non défaillante peut résilier de plein droit.



Réversibilité : à la cessation, l'Éditeur restitue les Données exploitables (exports CSV/JSON) dans un délai maximum de 30 jours, puis supprime définitivement les Données sous 90 jours, sauf obligations légales de conservation (voir [ATD](#)).

2.4. Tarifs et facturation

Tarifs exprimés en euros hors taxes, détaillés dans le bon de commande, avec éventuellement une part fixe (abonnement) et une part variable (utilisateurs, volumes, options).

Facturation mensuelle, trimestrielle ou annuelle par virement bancaire à 30 jours fin de mois par défaut. En cas de retard, pénalités équivalentes au taux BCE + 10 points et indemnité forfaitaire de 40 € (art. L.441-10 du Code de commerce).

Révision tarifaire annuelle avec un préavis de 3 mois ; le Client peut refuser et résilier sans pénalité à l'échéance.

2.5. Propriété intellectuelle

La Plateforme reste la propriété exclusive de l'Éditeur. Le Client bénéficie d'un droit d'usage non-exclusif et non-transférable limité à la durée de l'abonnement. Les Données saisies par le Client restent sa propriété. L'Éditeur est sous-traitant au sens du RGPD et se conforme à l'ATD.

2.6. Obligations de l'Éditeur

- Fournir un accès conforme à l'[Engagement de service \(SLA\)](#).
- Garantir la confidentialité et la sécurité des Données ([Politique de sécurité](#)).
- Assurer le support et la maintenance dans les conditions du SLA.
- Notifier toute violation de données dans un délai de 72 heures après prise de connaissance (art. 33 RGPD).
- Conserver les Données dans l'Union européenne (hébergement OVHcloud, région GRA).

2.7. Obligations du Client

- Régler les factures aux échéances prévues.
- Assurer la gestion de ses utilisateurs (création, désactivation, rôles) en vérifiant le bon fonctionnement des désactivation automatique.
- Vérifier la licéité des Données qu'il traite et disposer des bases légales appropriées.
- Informer les personnes concernées dont il traite les données via la Plateforme.
- Désigner un interlocuteur technique et un interlocuteur juridique/DPO.

2.8. Responsabilité

La responsabilité de chaque Partie est limitée aux dommages directs, prévisibles et démontrés. Les dommages indirects (perte de chiffre d'affaires, atteinte à l'image, perte d'opportunité commerciale) sont exclus.



La responsabilité globale de l'Éditeur, toutes causes confondues, est plafonnée au montant des redevances effectivement perçues au titre des 12 mois précédant le fait générateur, sauf faute lourde ou intentionnelle.

2.9. Confidentialité

Chaque Partie préserve la confidentialité des informations reçues de l'autre Partie (technologies, tarifs, données métier) pendant toute la durée du contrat et 5 ans après sa cessation.

2.10. Sous-traitance

L'Éditeur peut faire appel à des sous-traitants. La liste à jour est publiée sur [/legal/sous-traitants](#). Tout nouveau sous-traitant fait l'objet d'une information préalable permettant au Client de s'opposer pour motif légitime.

2.11. Protection des données personnelles

Les modalités de traitement des données personnelles sont détaillées dans [l'Accord de Traitement des Données \(ATD\)](#), qui fait partie intégrante du contrat.

2.12. Assurance

L'Éditeur déclare avoir souscrit une police d'assurance responsabilité civile professionnelle.

2.13. Force majeure

Les Parties ne sauraient être tenues responsables d'un manquement résultant d'un cas de force majeure au sens de l'article 1218 du Code civil.

2.14. Cession

Le contrat ne peut être cédé sans l'accord écrit de l'autre Partie, sauf cession dans le cadre d'une opération de restructuration, auquel cas une information préalable suffit.

2.15. Droit applicable et litiges

Les CGV sont soumises au droit français. En cas de litige, les Parties privilégient une résolution amiable ; à défaut, le tribunal de commerce du siège social de l'Éditeur est seul compétent, sauf dispositions d'ordre public contraires.

2.16. Contact

Support commercial : contact@iamisolutions.com · 07.69.79.98.92

3.SLA

Ce document détaille les engagements opérationnels d'IAMI pour le service SaaS IAM : disponibilité, support, sauvegardes, maintenance et gestion d'incident.

3.1. Disponibilité cible



Métrique	Engagement
Taux de disponibilité mensuel	≥ 99,5 % sur les heures ouvrées (8h–20h, jours ouvrés France)
Hors heures ouvrées	« best effort », pas de garantie contractuelle
Mesure	Monitoring synthétique toutes les 60 secondes

Exclusions : maintenance programmée (≥ 48 h avant), incidents tiers (opérateur, hébergeur), force majeure, environnement Client.

3.2. Fenêtre de maintenance

- Maintenance planifiée : dimanche 22h00 → lundi 02h00 (heure de Paris), annoncée ≥ 48 h à l'avance.
- Maintenance d'urgence (sécurité) : appliquée sans délai, notification le jour même.
- Déploiement continu : les déploiements mineurs n'impliquent pas d'interruption.

3.3. Support

Niveau	Prise en charge	Résolution cible
P1 — Bloquant (service indisponible)	< 1 h (heures ouvrées)	< 4 h
P2 — Majeur (fonction dégradée)	< 4 h	< 1 jour ouvré
P3 — Mineur (contournement possible)	< 1 jour ouvré	< 5 jours ouvrés
P4 — Évolution / question	< 2 jours ouvrés	selon roadmap

Heures ouvrées : lundi au vendredi 9h00–18h00 (Paris), hors jours fériés français. Contact : contact@iamisolutions.com.

3.4. Sauvegardes et continuité

Fréquence	Sauvegarde quotidienne complète + binlogs continus
Rétention	30 jours (quotidien) + 12 mois (mensuel)
RPO	≤ 1 h
RTO	≤ 4 h
Chiffrement	AES-256 au repos + TLS en transit
Emplacement	OVHcloud, région GRA (UE) + redondance inter-régions UE

3.5. Surveillance et détection

- Monitoring synthétique toutes les 60 s de la santé applicative.
- Monitoring infrastructure : CPU, mémoire, disques, base de données, Redis.
- Logs applicatifs centralisés (rotation 90 jours).
- Alerting : Email + SMS astreinte 24/7 (P1 uniquement).



3.6. Gestion d'incident

- Détection (monitoring ou signalement) — T0
- Qualification P1 / P2 / P3
- Communication initiale aux Clients actifs (statut, périmètre, ETA)
- Mobilisation astreinte si P1
- Communication toutes les 30 minutes pendant un P1
- Résolution + communication de rétablissement
- Post-mortem publié sous 7 jours pour tout incident P1

3.7. Sécurité (synthèse)

- Hébergement OVHcloud en France (GRA), datacenter ISO 27001.
- Chiffrement TLS 1.2+, hashage PBKDF2, tokens Fernet.
- Isolation multi-tenant (client_id + sous-domaine + JWT).
- Audit logs conservés 12 mois, scans Bandit + pip-audit en CI/CD.
- IA en local (Ollama) — aucune donnée envoyée à OpenAI / Anthropic / Google.

Voir la [Politique de sécurité](#) détaillée.

3.8. Notification de violation

Conformément à l'article 33 du RGPD :

- Notification à la CNIL dans un délai maximum de 72 h après prise de connaissance.
- Information du Client par email au DPO/référent RGPD dans le même délai.
- Information des personnes concernées si risque élevé pour leurs droits et libertés (art. 34).

3.9. Rapport de service

Sur demande annuelle : disponibilité mensuelle, liste des incidents P1/P2, synthèse des mises à jour sécurité, suivi des demandes RGPD.

3.10. Réversibilité

À la cessation du contrat : export complet J+0 à J+30, archivage technique jusqu'à J+90, suppression définitive au-delà. [Voir ATD Article 28](#).

3.11. Contact

Support : contact@iamisolutions.com · 07.69.79.98.92

DPO / RGPD : contact@iamisolutions.com

4.ATD



Cet accord (« ATD ») définit les conditions dans lesquelles IAMI, éditeur de la plateforme IAMI, traite les données à caractère personnel pour le compte du Client, dans le cadre du contrat SaaS qui les lie. Il constitue une annexe contractuelle aux CGV.

4.1. Parties

- Responsable de Traitement : le Client, personne morale désignée dans le bon de commande.
- Sous-Traitant : IAMI, 1 rue des liserons, SIREN 999430242.
- Point de contact RGPD : contact@iamisolutions.com.

4.2. Objet

Le Sous-Traitant est autorisé à traiter, pour le compte du Responsable, les données à caractère personnel nécessaires à l'exécution du service IAMI (gestion candidats, consultants, clients, prospects, entretiens, matching, assistant IA local, facturation, notes de frais, ordres de mission, DISC, dossiers de compétences).

4.3. Description du traitement

Élément	Détail
Finalité	Fourniture du service SaaS IAMI
Nature des opérations	Collecte, stockage, consultation, modification, analyse (matching, IA locale), suppression, anonymisation, export
Catégories de personnes	Candidats, consultants, salariés du Client, contacts clients/prospects, répondants enquêtes
Catégories de données	Identité, coordonnées, parcours, compétences, CV, DISC, entretiens, authentification, logs, RH, financier
Catégories particulières (art. 9)	Non collectées — responsabilité du Client si saisie en champ libre
Durée	Durée du contrat + réversibilité (30 j) + suppression (90 j)

4.4. Obligations du Sous-Traitant

- Traiter les données uniquement sur instruction documentée du Responsable (contrat, paramétrage, demandes support).
- Garantir la confidentialité : obligations contractuelles pour les personnes habilitées.
- Mettre en œuvre les mesures techniques et organisationnelles (voir [Politique de sécurité](#)).
- Aider le Responsable à répondre aux demandes d'exercice des droits (interface /rgpd, exports, support).
- Aider à respecter les obligations de sécurité, PIA/DPIA et consultation CNIL (art. 32 à 36).
- Notifier toute violation concernant les données du Responsable dans les 24 heures ouvrées suivant sa découverte.
- Supprimer ou restituer les données en fin de prestation.
- Mettre à disposition toute information nécessaire à démontrer le respect de l'art. 28 RGPD.
- IAMI rappelle que les outils d'IA (y compris les agents automatisés) ne prennent aucune décision à caractère juridique ou impactant directement une personne physique. Le



Client (Responsable de Traitement) conserve la pleine responsabilité des décisions finales (ex : sélection d'un candidat, affectation à une mission). IAMI fournit des recommandations ou analyses, mais ne se substitue pas au jugement humain.

4.5. Sous-traitance ultérieure

Le Client autorise le Sous-Traitant à recourir à des sous-processeurs, sous réserve :

- de les soumettre aux mêmes obligations par contrat écrit ;
- de publier la liste à jour sur [//legal/sous-traitants](#) ;
- d'informer le Client au moins 30 jours à l'avance de tout changement.

Le Client dispose d'un droit d'opposition motivé. À défaut d'accord, il peut résilier sans pénalité.

4.6. Transferts hors UE

Les données sont hébergées en France (OVHcloud, région GRA). Les transferts éventuels vers les sous-processeurs hors UE (DocuSign, GitHub, Google Maps si activés) sont encadrés par les Clauses Contractuelles Types adoptées par la Commission européenne (décision 2021/914), avec mesures complémentaires (chiffrement, minimisation).

4.7. Droits des personnes concernées

- Interface intégrée de traitement des demandes d'anonymisation (`/<client>/demande_anonymisation_rgpd`).
- Traçabilité des demandes via registre DataSubjectRequest.
- Réversibilité de l'anonymisation pendant un délai configurable (30 jours par défaut).
- Exports CSV pour la portabilité (art. 20).
- Registre Article 30 configurable, exportable en CSV/PDF via `/<client>/rgpd/registre`.

Le Client reste le point de contact direct des personnes concernées. Assistance du Sous-Traitant dans un délai raisonnable, au maximum 10 jours ouvrés.

4.8. Sécurité et notification de violation

Voir la [Politique de sécurité](#). Toute notification est faite à l'adresse RGPD communiquée par le Client à la signature.

4.9. Fin du traitement

- J+0 à J+30 — réversibilité : mise à disposition d'exports exhaustifs (CSV, JSON, dump SQL).
- J+30 à J+90 — archivage technique, données extractibles sur demande.
- J+90 — suppression définitive de production + sauvegardes dans les 30 jours suivants.

Une attestation de suppression signée est remise sur demande. Les données soumises à une obligation légale (factures 10 ans, etc.) sont conservées de manière isolée pour la durée nécessaire.

4.10. Audit

Le Client peut, au maximum une fois par an et avec préavis de 30 jours, demander un audit : questionnaire SIG, rapports internes (Bandit, pip-audit), ou audit sur site (à ses frais, auditeur soumis à confidentialité).



4.11. Durée et modification

L'ATD prend effet à la signature du contrat et reste en vigueur tant que le Sous-Traitant traite des Données pour le compte du Responsable. Toute modification substantielle est proposée par écrit.

4.12. Responsabilité

Chaque Partie est responsable des dommages résultant d'un manquement à ses obligations respectives RGPD/ATD, dans les limites des CGV

4.13. Droit applicable

Le présent ATD est régi par le droit français et le RGPD. Les litiges relèvent des juridictions compétentes selon les CGV.

5. Sous-traitants

Conformément à l'article 28.2 du RGPD et à l'**ATD** conclu avec nos clients, nous publions la liste à jour des sous-processeurs auxquels IAMI peut faire appel pour la fourniture du service IAMI.

Toute évolution (ajout, remplacement, suppression) fait l'objet d'une notification préalable aux clients au moins 30 jours à l'avance, leur permettant d'exercer leur droit d'opposition motivé.

Tableau des sous-traitants

Sous-traitant	Finalité	Données transmises	Localisation	Garantie / encadrement
OVHcloud	Hébergement laaS (serveurs, MySQL, stockage S3)	Toutes les données du service (chiffrées)	France (GRA)	DPA OVHcloud, ISO 27001 & 27701
Microsoft 365 (option Client)	Intégration Graph API : emails, calendrier, Teams	Contenu accédé par le Client via son propre tenant	Contenu accédé par le Client via son propre tenant	DPA Microsoft Online Services Terms, SCC
DocuSign (option)	Signature électronique (contrats, ODM)	Nom, email, PDF, métadonnées	États-Unis	DPA DocuSign + SCC + chiffrement tokens
GitHub (CI/CD)	Dépôt code source + CI (Bandit, pip-audit)	Aucune donnée personnelle client	États-Unis	DPA GitHub + SCC
Google Maps (option)	Géocodage inverse, itinéraires	Adresse postale professionnelle (lieu mission)	Monde	SCC + minimisation



OpenStreetMap / Nominatim	Géocodage (alternative libre)	Adresse postale	UE	Service public OSM
INSEE — API Sirene	Enrichissement SIRET → raison sociale	SIRET	France	API publique INSEE
Telegram Bot API (option — astreinte interne)	Notifications techniques internes (alerting)	Aucune donnée client — seulement métadonnées techniques	Monde	Chat privé adminou US selon configuration
Prestataire SMTP (Sendgrid / Brevo / Mailjet)	Envoi d'emails transactionnels (reset, invitations)	Nom, email, contenu transactionnel	UE ou US selon configuration	DPA + SCC si US

Zoom sur la localisation

- Toutes les données de production (base SQL, stockage documentaire, logs) sont hébergées en France, région OVHcloud GRA.
- Aucune IA générative tierce (OpenAI, Anthropic, Google Gemini, etc.) n'est utilisée. Les modèles sont exécutés localement (Ollama + embeddings locaux) sur notre infrastructure française.
- Les transferts hors UE éventuels (DocuSign, GitHub, Google Maps si activé) sont encadrés par des Clauses Contractuelles Types et des mesures complémentaires (chiffrement, minimisation).

Encadrement contractuel

Chaque sous-traitant ci-dessus est lié à IAMI par un contrat (DPA) garantissant :

- la finalité limitée du traitement,
- des mesures de sécurité équivalentes ou supérieures aux nôtres,
- la confidentialité,
- la notification rapide en cas de violation,
- la suppression des données à la fin de la relation,
- des droits d'audit.

Contact

Pour toute question concernant cette liste ou pour obtenir copie des DPA conclus avec nos sous-processeurs : contact@iamisolutions.com.

6. Politique RGPD

IAMI, éditeur de la plateforme IAMI, accorde une importance fondamentale à la protection de vos données personnelles. La présente politique décrit, conformément au Règlement Général sur la Protection des Données (Règlement UE 2016/679) et à la loi Informatique et Libertés (n° 78-17 du 6 janvier 1978 modifiée), les modalités de traitement des données personnelles liées à l'utilisation de la Plateforme.



6.1. Responsable du traitement

- Lorsque vos données sont traitées par un Client de IAMI (typiquement une ESN) : le Client est Responsable de Traitement. IAMI intervient en qualité de sous-traitant au sens de l'article 28 RGPD.
- Lorsque IAMI traite des données pour ses propres finalités (clientèle, prospection B2B, support, sécurité) : IAMI est Responsable de Traitement.

6.2. Quelles données collectons-nous ?

- Identité et contact : nom, prénom, email, téléphone, adresse professionnelle.
- Parcours professionnel : CV, expériences, diplômes, compétences, DISC, entretiens (avec consentement).
- Données RH (si salarié du Client) : contrat, poste, entretiens annuels, objectifs.
- Données de facturation : SIRET, adresse facturation, BIC / IBAN éventuel.
- Données techniques : adresse IP, logs de connexion, tentatives d'authentification.
- Navigation : cookies strictement nécessaires (session, CSRF). Aucun traceur tiers.

6.3. Finalités et bases légales

Finalité	Base légale
Gestion candidats, consultants, matching	Contrat / Intérêt légitime
CRM, devis, facturation	Contrat / Obligation légale (comptable)
Enregistrement d'entretien + résumé IA	Consentement explicite
Authentification, sécurité, logs	Intérêt légitime / Obligation légale (art. 32)
Authentification, sécurité, logs	Contrat / Intérêt légitime
Emails transactionnels	Contrat
Statistiques internes anonymisées	Intérêt légitime

6.4. Destinataires

- À l'intérieur du Client : utilisateurs habilités par rôle (recruteurs, consultants, direction) — RBAC strict.
- IAMI : un nombre restreint de collaborateurs habilités pour le support et l'exploitation.
- Sous-traitants techniques : voir liste publique.
- Aucun fournisseur d'IA tiers
- Les sorties des agents IA (ex : suggestions de matching, résumés d'entretiens) sont uniquement destinées aux Utilisateurs habilités du Client. Aucune décision automatisée n'est transmise à des tiers sans validation humaine préalable.

6.5. Localisation

Toutes les données sont hébergées en France, région GRA d'OVHcloud, dans un datacenter certifié ISO 27001. Les transferts éventuels hors UE sont encadrés par des Clauses Contractuelles Types.

6.6. Durées de conservation

Donnée	Durée
--------	-------



CV candidat non retenu	2 ans après dernier contact
Consultant actif	Durée de la relation, puis 5 ans
Contact client / prospect	3 ans après dernier contact
Audit logs	12 mois (configurable)
Factures / ODM / notes de frais	10 ans (obligation comptable)
Tokens expirés	30 jours après expiration
Tokens expirés	6 mois après transcription

À l'échéance : anonymisation réversible 30 jours puis suppression définitive.

6.7. Vos droits

- Accès (art. 15) — obtenir la confirmation et une copie des données traitées.
- Rectification (art. 16) — corriger des données inexactes.
- Effacement / droit à l'oubli (art. 17) — obtenir l'effacement.
- Limitation (art. 18) — restreindre temporairement un traitement contesté.
- Opposition (art. 21) — s'opposer à un traitement fondé sur l'intérêt légitime.
- Portabilité (art. 20) — recevoir vos données dans un format structuré.
- Décision automatisée (art. 22) — aucune décision à effet juridique n'est prise par l'IA seule.
- Retrait du consentement à tout moment.
- Directives post-mortem (art. 85 loi IEL).

Comment exercer vos droits :

- Si le responsable est un Client de IAMI (ESN) : adressez-vous directement au Client / à son DPO.
- Pour les traitements dont IAMI est responsable : contact@iamisolutions.com.

Réponse dans un délai maximum de 1 mois (prolongeable de 2 mois si complexe).

6.8. Sécurité

Voir [la Politique de sécurité](#) détaillée (chiffrement, contrôle d'accès, isolation multi-tenant, audit logs, tests automatiques, gestion d'incident).

6.9. Cookies

Uniquement des cookies strictement nécessaires au fonctionnement (session, CSRF, langue). Aucun cookie publicitaire, aucun traceur marketing, aucun pixel tiers. Exemption de consentement CNIL.

6.10. Violation de données

Notification à la CNIL dans un délai de 72 heures après prise de connaissance (art. 33).
Information des personnes si risque élevé (art. 34).

6.11. Recours — CNIL

Si vos droits ne sont pas respectés après nous avoir contactés, vous pouvez saisir la CNIL :



IAMI

- En ligne : www.cnil.fr/fr/plaintes
- Par courrier : 3 Place de Fontenoy, TSA 80715, 75334 Paris Cedex 07

6.12. Contact

Délégué à la Protection des Données : contact@iamisolutions.com

Support général : contact@iamisolutions.com

Adresse postale : 1 rue des liserons 75013 Paris

6.13. Modifications

Cette politique peut être mise à jour pour refléter des évolutions légales, techniques ou organisationnelles. La version en vigueur est celle publiée sur www.iamisolutions.com/legal/politique-rgpd.html.

7. Politique de sécurité

La présente politique décrit les mesures techniques et organisationnelles mises en œuvre par IAM I pour assurer la sécurité et la confidentialité des données traitées via la plateforme IAM I, conformément à l'article 32 du RGPD.

7.1. Hébergement

- Hébergeur : OVHcloud (OVH SAS), cloud souverain français.
- Région : GRA (Gravelines, Hauts-de-France, Union européenne). Aucune donnée de production n'est stockée hors UE.
- Certifications datacenter : ISO 27001, ISO 27701, ISO 50001, HDS pour les offres compatibles.
- Redondance haute disponibilité intra-région, sauvegardes chiffrées répliquées en second site UE.
- DPA OVHcloud signé, clauses RGPD intégrées.

7.2. Architecture applicative

7.2.1. Isolation multi-tenant

- Toutes les tables métier portent une colonne client_id indexée.
- À chaque requête, vérification stricte : sous-domaine <-> client_id du token/session <-> appartenance de l'utilisateur.
- Aucun échange transverse entre tenants n'est techniquement possible depuis l'API applicative.

7.2.2. Contrôle d'accès (RBAC)

- Rôles attribués via UserRoleAssignment.
- Chaque fonctionnalité et endpoint sensible est protégé par un décorateur de permission.
- Séparation stricte administrateur / utilisateur standard.

7.2.3. Authentification



- Flask-Login (session cookie HttpOnly, Secure, SameSite=Lax).
- JWT pour les API, liés au client_id.
- Hashage PBKDF2 avec salage aléatoire.
- Politique de mot de passe configurable par tenant.
- Protection brute-force : rate limiting Redis + verrouillage (LoginAttempt).
- MFA — roadmap : TOTP + codes de récupération.

7.2.4. Chiffrement

Donnée	Méthode	Algorithme
Mots de passe	Hashage	PBKDF2-SHA256 + sel
Tokens OAuth (DocuSign, Microsoft)	Chiffrement symétrique	Fernet (AES-128 CBC + HMAC-SHA256)
Snapshots RGPD réversibles	Chiffrement symétrique	Fernet
Données en transit	TLS 1.2+ (HSTS)	ECDHE + AES-GCM
Sauvegardes	Au repos	AES-256

Les clés sont stockées dans des variables d'environnement et GitHub Environment Secrets pour la CI ; jamais dans le code source.

7.3. Sécurité web

- HTTPS obligatoire, HSTS actif (max-age=31536000; includeSubDomains).
- CSP stricte : default-src 'self', pas de CDN non vérifié.
- X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy strict.
- CSRF (Flask-WTF) sur tous les formulaires mutatifs.
- Rate limiting Redis global et par endpoint sensible.

7.4. Intelligence Artificielle

100 % des modèles d'IA tournent en local sur nos serveurs OVHcloud :

Aucune donnée n'est transmise à OpenAI, Anthropic, Google (Gemini), Cohere, Mistral AI Cloud, ou tout autre fournisseur d'IA externe. Les résumés d'entretien, analyses de CV, chat IA, agents IA sont produits entièrement dans notre périmètre UE.

7.5. Journalisation et audit

- Audit log applicatif (AuditLog) : authentications, changements sensibles (rôles, permissions, suppressions, anonymisations RGPD, exports), accès aux données particulières.
- Conservation 12 mois par défaut (configurable par tenant).
- Les champs PII (email, IP) sont anonymisés automatiquement lors du droit à l'oubli.
- Logs techniques : rotation 90 jours.

7.6. Sauvegarde et reprise

- Sauvegarde quotidienne complète + binlogs continus (PITR).
- Rétention : 30 j quotidien + 12 mois mensuel.
- Chiffrement AES-256 au repos, accès MFA restreint.
- RPO ≤ 1 h, RTO ≤ 4 h.



- Tests de restauration trimestriels sur environnement isolé.

7.7. Sécurité du développement

- Code source GitHub (org privée, branches protégées, revue obligatoire).
- CI/CD automatisée :
 - Bandit — analyse statique Python.
 - pip-audit — CVE sur dépendances.
 - Tests unitaires et d'intégration .
- Revue de code systématique, signature GPG des commits recommandée.
- Secrets gérés via GitHub Environment Secrets et variables d'environnement production.
- Dependabot / revue régulière des dépendances.

7.8. Gestion des tiers

Voir *Déclaration des sous-traitants*. Chaque sous-traitant est encadré par un DPA + SCC si hors UE.

7.9. Accès internes

- Principe du moindre privilège pour les collaborateurs.
- Accès production réservé à un nombre restreint d'administrateurs, avec MFA et journalisation.
- Séparation stricte dev / staging / production.
- Offboarding : révocation immédiate des accès au départ.

7.10. Gestion des vulnérabilités

- Scans automatiques à chaque déploiement (Bandit, pip-audit).
- Application des patches : critiques < 48 h, hauts < 7 j, moyens < 30 j.
- Signalement responsable : contact@iamisolutions.com (accusé de réception sous 48 h ouvrées).

7.11. Gestion d'incident

- Détection (monitoring ou signalement).
- Qualification dans l'heure.
- Confinement / mitigation.
- Investigation forensic.
- Notification CNIL dans les 72 h si violation de données personnelles (art. 33).
- Communication aux personnes concernées si risque élevé (art. 34).
- Post-mortem écrit sous 7 jours.

7.12. Mesures organisationnelles

- Formation annuelle sécurité et RGPD.
- Clauses de confidentialité dans les contrats.
- Charte informatique interne signée.
- PIA/DPIA pour les traitements à risque élevé.



- Registre des traitements maintenu à jour et accessible aux clients dans `/<client>/rgpd/registre`.

7.13. Conformité

- Hébergement ISO 27001 & 27701 (via OVHcloud).
- Conformité RGPD démontrable (audit interne, vérifications CNIL).

7.14. Contact sécurité

Signalement vulnérabilité : contact@iamisolutions.com

Nous accusons réception sous 48 h ouvrées et traitons les rapports avec diligence et confidentialité.

8.App Mobile

Responsable du traitement : l'employeur ou l'organisation cliente qui vous fournit l'accès à IAMl (données métier hébergées sur la plateforme). Pour toute question relative à votre compte et aux données de votre organisation, contactez l'administrateur IAMl de votre structure.

Éditeur de la plateforme web et API : IAMl — contact général : contact@iamisolutions.com.

URL du portail (exemple production) : <https://app.iamisolutions.com>

8.1. Objet

La présente politique décrit les traitements de données à caractère personnel liés à l'application mobile IAMl (ci-après « l'App ») lorsque vous l'utilisez pour accéder aux fonctionnalités de la plateforme IAMl (recrutement, missions, notes de frais, réunions, tableaux de bord, etc.). Elle complète les engagements de votre employeur / donneur d'ordre et les éventuelles mentions d'information déjà fournies sur le portail web.

8.2. Données traitées via l'App

Selon les modules activés pour votre compte, l'App peut permettre d'accéder ou de produire notamment :

- Identifiants de connexion : identifiant (souvent adresse e-mail), jeton d'authentification (JWT) délivré par le serveur IAMl après authentification.
- Données de profil : par exemple prénom, nom, identifiant utilisateur, code client / espace (« client ») auquel vous êtes rattaché.
- Données métier transmises par les API IAMl : contenus que vous consultez ou saisissez dans l'App (candidats, besoins, missions, notes de frais, réunions, messages d'assistant, etc.) — alignés sur les données déjà présentes sur la plateforme pour votre organisation.
- Contenus multimédias locaux que vous choisissez d'ajouter volontairement : photographies ou fichiers issus de la galerie ou de l'appareil photo pour les justificatifs



de notes de frais ; enregistrements audio pour les réunions lorsque vous lancez l'enregistrement dans l'App. Ces contenus sont ensuite traités selon les flux prévus par la plateforme (téléversement, transcription côté serveur si applicable, etc.).

8.3. Finalités

- Permettre l'authentification sécurisée et le maintien de session vers les API IAMI.
- Afficher et synchroniser les fonctionnalités métier autorisées pour votre rôle.
- Permettre la capture de pièces justificatives et d'audio de réunion lorsque vous utilisez ces fonctions, dans le cadre professionnel décrit dans l'App.

8.4. Stockage sur l'appareil (iPhone / iPad)

L'App utilise le Trousseau sécurisé iOS (Keychain) via la bibliothèque Flutter `flutter_secure_storage` pour conserver notamment le jeton d'accès et des informations de session nécessaires à la reconnexion. Ces données restent sur votre appareil et ne sont pas lisibles par d'autres applications.

Vous pouvez supprimer ces données en vous déconnectant depuis l'App et/ou en désinstallant l'application.

8.5. Communications réseau

Les échanges entre l'App et les serveurs IAMI passent par des connexions chiffrées (HTTPS / TLS), sur le domaine de la plateforme configurée pour votre organisation (en production, typiquement sous `app.iamisolutions.com` avec un préfixe client).

Les cartes (lorsque l'App affiche une carte) peuvent charger des tuiles auprès d'un fournisseur cartographique tiers : seuls les paramètres techniques nécessaires à l'affichage (par ex. tuiles géographiques) sont échangés ; suivez aussi la politique de confidentialité du fournisseur concerné si besoin.

8.6. Périmètre des API et journaux serveurs

Les opérations effectuées via l'App sont traitées côté serveur comme des accès à la plateforme IAMI : journaux techniques (adresse IP, horodatage, type d'action, identifiants techniques), sauvegardes métier et sécurité (prévention des abus) peuvent être conservés selon les paramètres et obligations de votre organisation et du responsable de traitement.

8.7. Destinataires

Les données accessibles via l'App sont destinées aux personnes habilitées au sein de votre organisation (managers, RH, consultants, etc.) selon les droits IAMI, ainsi qu'aux sous-traitants techniques impliqués dans l'hébergement et l'exploitation de la plateforme (hébergeur, services d'infrastructure), dans le respect des contrats et du RGPD. Voir [Déclaration des sous-traitants](#).

8.8. Durée de conservation



La durée de conservation des données métier et des journaux est définie par le responsable du traitement (votre employeur / organisation) et par la configuration IAMI. Les données stockées localement sur l'appareil suivent les règles de la section 4.

8.9. Vos droits (RGPD)

Selon les cas, vous pouvez exercer vos droits d'accès, de rectification, d'effacement, de limitation, d'opposition et de portabilité auprès du responsable du traitement (votre employeur ou l'administrateur désigné). Pour toute demande relative à l'édition de la plateforme :

contact@iamisolutions.com.

8.10. Modifications

Nous pouvons mettre à jour cette politique pour refléter l'évolution de l'App ou des exigences légales. La date de mise à jour en tête de page sera ajustée ; les changements substantiels peuvent également être portés à votre connaissance par votre organisation ou via l'App Store.

8.11. Contact

Pour toute question relative à cette politique ou à l'App mobile IAMI :

contact@iamisolutions.com

